

MCCoE CYBERSECURITY APPRENTICESHIP PROGRAM
PROJECT 6 OF 8 — PART 2: FRAMEWORKS + EXECUTIVE SUMMARY
SOLARWINDS SUPPLY CHAIN ATTACK (2020)

Nation-State Attack · Supply Chain · 18,000 Victims · 9 Months Undetected

THIS PROJECT: Apply the NIST CSF and pentesting methodology. Write and present your professional Executive Summary. This project ends with your Executive Summary submission (100 points).

PROJECT 6 · DAY 6	MONDAY — NIST CSF — DEFENSIVE FAILURE ANALYSIS	1-2 HRS
-------------------	--	---------

OBJECTIVE: Students apply all 5 NIST Cybersecurity Framework functions to identify exactly what the organization did wrong and what they should have done.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:20	Project Launch + Review	Quick recap of last project findings. Preview this project: today = defender perspective. What failed? What should have existed?
0:20-0:50	Lecture: NIST CSF	Teach the 5 functions. Draw a timeline on the board — overlay NIST. Show: Identify/Protect are BEFORE. Detect/Respond/Recover are DURING and AFTER.
0:50-1:40	NIST Failure Analysis	Students fill out the NIST table: for each function — specific failure + specific corrective action. No vague answers.
1:40-2:00	Critical Failure Vote	Which NIST function had the most catastrophic failure? Students vote and justify their answer. Discuss.

🎯 **OBJECTIVE:** Students map the attacker's actions to the 5 pentesting phases. Think like an attacker to become a better defender.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:30	Lecture: 5 Pentest Phases	Teach Reconnaissance, Scanning, Gaining Access, Maintaining Access, Covering Tracks. Why thinking like an attacker makes you a better defender.
0:30-1:10	Methodology Mapping	Students map the attacker's specific actions in this incident to each of the 5 phases. Include specific tools or techniques used.
1:10-1:40	Attacker vs Defender Game	For each phase: students suggest what the attacker did AND what a defender could have done to detect or stop it.
1:40-2:00	Homework Briefing	Assign: Tonight, outline your full Executive Summary using the template. Every section must have at least 3 bullet points before you write.

🎯 **OBJECTIVE:** Students develop and workshop 5 specific, actionable recommendations. Peer collaboration to pressure-test each recommendation.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:20	From Here On Out Review	Go through the "From Here On Out" section together. Discuss: are these the right priorities? Would you add anything?
0:20-1:00	Recommendations Workshop	Students draft their 5 recommendations with justification. Then pair up: each partner challenges one recommendation — is it specific enough? Does it address this incident?
1:00-1:30	Priority Debate	Class votes on the single most important recommendation. Each student defends their #1. Group builds a consensus top 5.
1:30-2:00	Executive Summary Drafting	

🎯 **OBJECTIVE:** Students complete peer review, deliver professional executive summary presentations, submit, and debrief the full incident.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:30	Writing + Peer Review	Students finalize all 9 sections of the Executive Summary. Swap with a partner: (1) strongest section, (2) one section needing more specifics, (3) one fact missed.
0:30-1:00	Revision Time	
1:00-1:45	Presentations + Submission	Each student presents 3-5 minutes. Collect completed Executive Summaries (100 pts). Class gives structured feedback: one strength, one specific improvement.
1:45-2:00	Full Debrief + Next Project Preview	What is the single most important lesson from this incident? What would you tell an IT team to do first thing Monday morning? Preview the next project.

NIST CSF FAILURE ANALYSIS REFERENCE

NIST FUNCTION	WHAT FAILED	WHAT SHOULD HAVE HAPPENED
Identify	FAILED — Organizations trusted SolarWinds without verifying supply chain integrity; no SBOM requirement	Conduct regular asset inventories, vendor risk assessments, and map all third-party connections
Protect	PARTIAL — Some had segmentation limiting damage; most did not restrict what Orion could access internally	Implement NIST SP 800-53 controls. Enforce MFA, patching SLAs, network segmentation
Detect	FAILED — Undetected for 9+ months; signature-based tools cannot detect valid signed updates	Deploy SIEM, IDS/IPS, behavioral analytics. Set up 24/7 monitoring with mandatory alert response SLAs
Respond	PARTIAL — Once FireEye disclosed, government and private sector coordinated rapid response	Develop and TEST an incident response plan. Establish clear escalation paths
Recover	ONGOING — Full recovery took months; some systems rebuilt from scratch; ED 21-01 required complete rebuild	Implement and test backup/recovery. Define RTO and RPO. Conduct tabletop exercises regularly

ATTACKER METHODOLOGY — 5 PHASES REFERENCE

PHASE	WHAT THE ATTACKER DID IN THIS INCIDENT
Reconnaissance	Deeply studied SolarWinds' build process — the most sophisticated supply chain recon ever documented
Scanning	SUNBURST spent 12–14 days quietly scanning for security tools before activating
Gaining Access	Exploited victim trust in a legitimate, digitally signed software update — the ultimate trusted access
Maintaining Access	Deployed TEARDROP and Cobalt Strike; used legitimate cloud tools and admin accounts to blend in
Covering Tracks	Mimicked legitimate Orion traffic; used DNS for C2; stayed dormant for weeks to evade sandboxes

"FROM HERE ON OUT" — RECOMMENDATIONS REFERENCE

🔗 **NOTE:** These are the controls that, if in place, would have prevented or significantly reduced this breach.

- **MANDATE:** Software Bill of Materials (SBOM) — every piece of software must declare all components it contains
- **MANDATE:** Zero Trust Architecture — even trusted software from known vendors must have limited, monitored access
- **MANDATE:** Behavioral monitoring — signature-based tools failed here; detect anomalous behavior, not known-bad signatures
- **IMPLEMENT:** Threat hunting program — proactively search for threats rather than waiting for alerts
- **IMPLEMENT:** DNS anomaly monitoring — SUNBURST used DNS for C2; unusual DNS patterns must trigger investigation
- **IMPLEMENT:** Third-party software access controls — monitoring tools should have limited network access even when they need visibility

REFERENCES & RESOURCES

- FireEye Blog: "Highly Evasive Attacker Leverages SolarWinds Supply Chain" (December 13, 2020) — [mandiant.com](https://www.mandiant.com)
- CISA Emergency Directive 21-01 — [cisa.gov/emergency-directive-21-01](https://www.cisa.gov/emergency-directive-21-01)
- nvd.nist.gov/vuln/detail/CVE-2020-10148 — full technical details
- U.S. Senate Intelligence Committee: SolarWinds Hearing (February 23, 2021)
- Executive Order 14028 on Improving the Nation's Cybersecurity — [whitehouse.gov](https://www.whitehouse.gov)
- MITRE ATT&CK: attack.mitre.org — search T1195, T1071, T1027